信息安全研究 Journal of Information Security Research 第8卷 第12期 2022年12月 Vol.8 No.12 Dec. 2022
DOI:10.12379/j.issn.2096-1057.2022.12.01

物联网固件漏洞安全检测综述

李 涛[1] 田迎军[1] 葛阳晨[2] 田 源[2] 李 剑[3]
[1](山东高速建设管理集团有限公司 济南 250098)
[2](北京邮电大学人工智能学院 北京 100876)
[3](北京邮电大学网络空间安全学院 北京 100876)
(552126247@qq.com)

A Survey of IoT Firmware Vulnerability Security Detection

Li Tao[1], Tian Yingjun[1], Ge Yangchen[2], Tian Yuan[2], and Li Jian[3]
[1](*Shandong Hi-Speed Construction Management Group Co., Ltd., Jinan* 250098)
[2](*School of Artificial Intelligence, Beijing University of Posts and Telecommunications, Beijing* 100876)
[3](*School of Cyberspace Security, Beijing University of Posts and Telecommunications, Beijing* 100876)

Abstract With the advent of the Internet of everything, the security issues of the IoT have become more and more important, especially the economic losses caused by security risks and attacks caused by firmware vulnerabilities in the IoT. Efficient firmware vulnerability detection technology has increasingly become the key to ensuring the security of IoT devices. Therefore, studying the methods and technologies related to firmware vulnerability security detection in the IoT has essential theoretical significance and practical value. This paper analyzes the reasons for the frequent security problems of IoT firmware, summarizes the main security threats faced by IoT firmware, and targets the firmware. Based on the challenges faced by vulnerability analysis, the existing firmware vulnerability detection methods are reviewed. Through the analysis of the advantages and disadvantages of different methods, it provides guidance for further improving the intelligence, precision, automation, effectiveness, and scalability of the firmware security defect detection method. Finally, future research in IoT firmware vulnerability security detection is prospected.

Key words IoT; firmware; vulnerability detection; security; firmware security

摘 要 随着万物互联时代的到来,物联网的安全问题越来越突出,尤其是物联网中由于固件漏洞引起的安全隐患或攻击行为导致的经济损失越来越大.高效的固件漏洞检测技术越来越成为保障物联网设备安全的关键,因此研究物联网中固件漏洞安全检测相关方法与技术具有重要的理论意义和实用价值.分析了物联网固件安全问题频发的原因,归纳了物联网固件面临的主要安全威胁,针对固件漏洞分析所面临的挑战,综述了现有固件漏洞检测方法.通过对不同方法优势与不足的分析,为进

收稿日期:2021-09-14
基金项目:国家自然科学基金项目(61472048)
通信作者:田源(redrainiety@bupt.edu.cn)
引用格式:李涛,田迎军,葛阳晨,等. 物联网固件漏洞安全检测综述[J]. 信息安全研究,2022,8(12):1146-1155

(C)1994-2022 China Academic Journal Electronic Publishing House. All rights reserved. http://www.cnki.net

一步提升固件安全缺陷检测方法的智能化、精准化、自动化、有效性、可扩展性提供指导.最后,对物联网固件漏洞安全检测进行了展望.

关键词 物联网;固件;漏洞检测;安全;固件安全

中图法分类号 TP309

随着物联网(Internet of thing, IoT)市场规模的快速增长,越来越多的设备进入人们的生活.万物互联成为网络发展的重要方向.《2019—2020中国物联网发展年度报告》中指出,全球物联网设备连接数保持强劲增势,设备接入量超70亿台,我国物联网产业规模已超1.2万亿元,同时随着5G、人工智能、区块链、IPv6等新一代信息技术的发展,物联网将会得到更加快速的发展.预计到2025年,活跃的物联网设备数量预计将达到342亿台[1],物联网将深刻影响到人类生产和生活的各个方面,包括智能家居、智能医疗、智能交通、智能电网等其他工业与公共基础设施[2].

另一方面,物联网在为公众生活与工作提供便利的同时,其安全面临着严峻挑战.物联网安全问题不仅能给用户带来财产损失,严重时甚至会威胁用户的生命安全[3].2016年CNVD公开发布的网络设备漏洞每年以30%左右的速度增长.仅2019年就出现了智能门锁安全漏洞、物联网摄像头任意访问、儿童手表暴露隐私等众多物联网设备安全问题.众多的物联网设备固件安全问题不仅给用户造成极大的隐私及财产安全威胁,也阻碍了物联网行业的迅猛发展.据统计80%的物联网设备采用弱密码算法,70%的物联网通信过程未加密,90%的物联网固件存在安全隐患.

因此,设计并实现快速、有效的物联网设备固件内存漏洞检测工具,能够帮助安全研究员指明物联网设备中的安全问题,同时能够帮助物联网厂商快速定位到代码设计缺陷,从而更好地促进物联网产业的发展.综上所述,针对物联网设备固件的漏洞分析技术具有重要研究意义.

1 固　　件

1.1 固件的定义

固件(firmware)通常是指一种嵌入在硬件设备中的软件,是运行在物联网设备上的核心软件之一,担任着一个系统最基础最底层工作.例如个人计算机的基本输入输出系统(basic input output system, BIOS)、统一可扩展固件接口(unified extensible firmware interface, UEFI)可能仅包含设备的基本功能,并且只能为更高级别的软件提供服务.对于不太复杂的设备,固件充当设备的完整操作系统,执行所有控制、监视和数据操作功能.图1所示为物联网设备的结构:

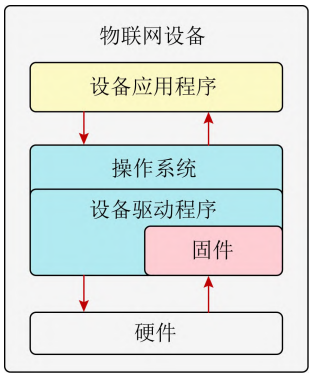

图1　物联网设备结构

固件是一段以二进制形式存于只读存储器的程序,在以前,是在生产过程中被写入硬件固化,且后期无法修改,需要重新生产.随着技术的发展固件可以写入EPROM(可擦写可编程只读存储器)或EEPROM(电可擦可编程只读存储器)中,以满足对固件维护更新的需求.其中,修复错误、向设备添加新功能、提高设备的稳定性和工作效率是固件维护更新的常见原因.

1.2 固件的分类与特点

根据固件是否包含操作系统以及包含操作系统的种类,可以将固件分为3类:

1) 单片机固件.

单片机固件是不包含操作系统的,通常以单个二进制镜像的形式存在,固件中仅包含一个简单的循环控制,负责不断接收外部环境发送产生的中断信号,基于底层硬件驱动完成处理外部事件.虽然小巧,但是功能简单,可移植性较差.

(C)1994-2022 China Academic Journal Electronic Publishing House. All rights reserved. http://www.cnki.net

2）通用操作系统固件.

随着硬件性能的提升，物联网设备中被移植了以 Linux 为主的通用操作系统，如 busybox，uClibc 提供轻量级的用户空间环境.这些修改通常保留了 Linux 的内核，该类固件开发简单，可直接使用操作系统中的网络通信系统、文件管理系统、进程调度系统等，具有高效使用 CPU 和内存、运行稳定、可移植性高的特点，缺点是固件所需的存储较大.这类设备包括智能路由器、智能摄像头等.

3）实时操作系统固件.

实时操作系统（real time operating system，RTOS）指的是没有缓冲区延迟、能够实时处理数据的操作系统.RTOS 可以分为软实时操作系统和硬实时操作系统.软实时只要按照任务的优先级，尽可能快地完成操作即可；硬实时则要求在规定的时间内必须完成任务，这是在操作系统设计时保证的.常见的实时操作系统有 VxWorks[4]，FreeRTOS[5]，其中 FreeRTOS 因为其开源免费、可在资源有限的微控制器中运行等优点被学术界和工业界广泛应用.在物联网设备中使用 RTOS，能够让设备最大化利用有限 CPU 资源；此外对于开发人员而言，可以简化固件程序设计、提高开发效率.实时操作系统的物联网设备在追求任务实时性的同时有低功耗的需求.常见的配备实时操作系统的设备有智能插座、智能灯泡等.

2 物联网固件安全问题频发的原因

物联网的概念自 2005 年提出，期间随着硬件设备、云计算、5G 等技术不断发展成熟，相关的物联网产业以此为基础在智能家居、智能汽车、智慧医疗、工业控制、智慧城市等领域也迅速发展扩大.在物联网环境下，嵌入式设备数目的日益增长，固件系统规模逐渐复杂，以及物联网设备低功耗、有限资源环境下缺失有效的保护机制，使得固件安全问题日益严峻.

2010 年曝光的震网病毒[6]是第 1 个专门定向攻击真实世界中基础能源设施的蠕虫病毒，包括核电站、水电站、国家电网等工业与公共基础设施都遭受了大规模的破坏.2019 年 3 月 7 日，委内瑞拉国内，包括首都加拉加斯在内的大部分地区的电力系统受到破坏，造成大规模持续停电[7].停电导致大规模的交通拥堵，与此同时学校、医院、工厂、机场等都受到严重影响，网络通信设备也无法正常使用.2021 年 5 月，美国最大燃油运输管道公司科洛尼尔[8]和全球最大肉类供应商 JSB 集团[9]遭勒索攻击，造成短期内石油、肉类供应紧张.

很多物联网设备固件安全问题频频发生的主要原因有以下 3 个：

1）开发人员对代码安全性认识不足.

固件大多数是用 C 语言编写的，虽然 C 语言本身提供了各种 API 确保内核安全，但是程序关键步骤的安全需要开发人员作出判断，常见的如入参检查、数组越界问题、死锁问题、异常处理、密码硬编码等问题.有相当数量的固件开发者并没有安全编码的经验，同时对代码安全性认识不足，导致在实际编程过程中存在疏漏，最终成为固件漏洞.在设备接入互联网运行的情况下，这样的漏洞将存在安全隐患，极易成为黑客的攻击目标.

2）物联网设备厂商缺乏安全意识.

一方面，厂商为快速推出产品追求利润而忽略或者不重视物联网设备的安全，在产品从开发到上线的过程中，缺少专业人员对设备代码的审计、对设备进行安全测试，这些规范流程的缺失导致物联网设备的安全问题经常发生且相关的安全防护水平较低.根据 Ponemon 研究所[10]在《2017 年移动物联网应用安全研究报告》中的数据说明，大多数物联网设备制造厂商在最开始产品设计时并没有在安全方面进行考虑.并且在将近 1 000 名受访问人员中只有 30%左右的人表示，他们的企业会使用足够的资金在物联网设备的安全上.而多数企业则说明，安全性不是其产品设计的关键.

另一方面，设备厂商对现有固件的维护与更新，需要巨大的投入但利润收益不显著，供应商对已经出现问题的过期固件停止维护或者更新不及时，因此攻击者可以利用在低版本固件中存在的已知漏洞对设备进行攻击.当前正在使用的智能硬件设备中的固件普遍使用的是过时的版本，其中可能包含漏洞.国家对物联网产品的安全性缺乏强制性或惩罚性的要求也是原因之一.2020 年，轻量级 TCP/IP 软件库被披露出 19 个 0-day 漏洞[11]，可能导致不同行业的数十亿 IoT 设备面临着远程攻击的风险.

此外，从消费者的角度而言，他们关注的是产

(C)1994-2022 China Academic Journal Electronic Publishing House. All rights reserved. http://www.cnki.net

品设备功能的使用，固件的更新不仅要求消费者具有一定的网络基础知识，而且升级后的固件能否稳定以及是否会带来性能的降低等不确定因素也影响了消费者主动去更新固件，这些都导致当前智能硬件设备问题众多.

3）固件设备计算、存储资源有限.

相比计算机和智能手机，智能设备硬件设计的复杂度相对较低.这大大降低攻击者通过硬件分析发起攻击的成本.由于物联网设备的计算机能力和存储能力有限，无法将传统安全的一些防御措施部署到设备固件中，这些因素给设备的厂商和维护人员提出了安全性挑战.如配用电物联网终端普遍存在计算资源有限的问题，难以采用有较高计算资源要求的加密认证技术[12].2014 年，研究人员破解了西班牙电力公司智能电表采用的 AES-128 对称加密算法，通过向电表注入恶意代码，实现了对电表标识码篡改、修改电量读数进行窃电，甚至以此为跳板攻击其他电表，切断供电，造成事故.

综上，在智能物联网设备飞速发展的过程中，其安全状态却不容乐观.由于固件提供了设备最基础的功能实现，所以固件的安全性对整个设备的影响至关重要.厂商急于开发出新功能和新产品吸引消费者从而扩大智能家居市场份额，但受到产品上市时间以及研发成本的限制，安全人员无法在开发周期中投入足够多和广泛的安全测试工作；同时受限于固件设备的硬件资源，无法部署完善的防御系统.这些吸引了许多黑客组织对智能设备系统进行攻击和利用.

3 物联网设备固件面临的安全威胁

根据国家互联网应急中心的 CNVD 统计显示，2020 年公开收录的通用型联网智能设备漏洞 3 047 个，新增漏洞数量呈显著增长趋势，同比增长 28%[13].这些安全漏洞涉及的漏洞类型如图 2 所示，主要的漏洞包括设备权限绕过、信息泄露、缓冲区溢出、远程代码执行、弱口令等.漏洞涉及的设备类型主要包括家用路由器、网络摄像头、防火墙等.

其中和固件相关的漏洞包括固件认证绕过漏洞、内存漏洞、逻辑漏洞、命令注入漏洞、固件修改漏洞等.

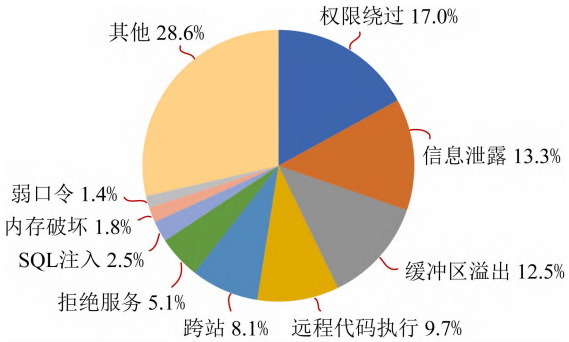

图 2　联网智能设备漏洞类型分布

3.1 固件认证绕过漏洞

在所有的物联网设备漏洞类型中，攻击者着重关注的是认证绕过攻击，常常将其作为入侵的切入点.未能实施强大的访问策略和身份验证控制的组织可能会允许攻击者绕过身份验证，可让攻击者执行各种恶意操作.

物联网设备由于其万物互联的属性，所有设备都需要通信交互，而交互不可避免需要对对方的身份进行认证.设备的认证不仅包括对云平台的认证和对用户的认证，还包括对其他设备的认证，只有通过认证的对象才能获得执行相关操作的权限或访问敏感数据，物联网设备交互模型如图 3 所示.然而，由于固件中存在密码硬编码、口令设置过于简单、开发过程中留下的隐藏认证接口等问题，以及其他不严谨的认证逻辑，攻击者可以加以利用并绕过设备身份验证机制，从而控制设备，获取敏感信息，执行各种恶意操作，严重威胁用户财产及其人身安全.因此，探究智能设备中的认证绕过漏洞是极具意义的.

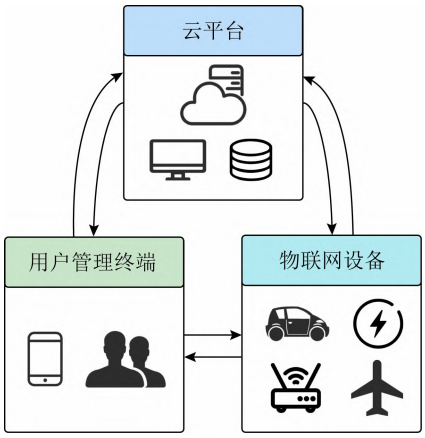

图 3　物联网设备交互模型

(C)1994-2022 China Academic Journal Electronic Publishing House. All rights reserved. http://www.cnki.net

3.2 内存漏洞

内存漏洞在固件漏洞中最常见[14]，非预期的内存访问导致堆栈内存发生错误，攻击者可以利用此漏洞对内存进行任意读写.内存漏洞的分类有以下几种：栈堆溢出漏洞、内存泄露漏洞、空指针异常漏洞、格式化字符串漏洞、整数溢出漏洞、数组越界漏洞等.外部不合法的输入是导致内存漏洞的直接原因.通过构造特定的输入，攻击者可以引发固件程序缓冲区溢出、重启、抛出异常、挂起、敏感信息泄露、拒绝服务等行为.例如，Swisslog Healthcare Nexus Panel 是 Swisslog Healthcare 公司的一款医疗设备.Nexus Control Panel 7.2.5.7 之前版本存在整数下溢漏洞(CNVD-2021-62181)[15]，攻击者可利用该漏洞覆盖内部队列数据结构，从而实现远程代码执行，甚至会危害患者生命健康.

3.3 逻辑漏洞

在计算机程序设计中，不严谨的逻辑会产生逻辑漏洞，导致程序运行不正确，但程序不会异常终止或崩溃.逻辑漏洞通常不会被立即识别出来，但会产生意想不到的或不需要的输出和行为.如果攻击者利用逻辑设计上的漏洞构造特定的输入，就可以使程序的正常功能发生偏移.例如设备权限等级设计不合理，低权限的用户能够执行一些高危操作，如修改、删除核心的配置文件，设备的底层将会受到严重的破坏；如果设备间的通信没有经过加密处理或者加密算法过于简单，那么这样的逻辑是不严谨的，会使设备间的数据传输遭到监听和篡改；如果将使用到的账号、密码硬编码于代码中，或者在配置文件中保留如数据库地址等敏感信息，通过反汇编技术，攻击者可以轻易获得这些信息并入侵设备系统.此外，为了给用户提供便利，设备厂商一般会为设备提供初始化的登录账号和密码，如果用户未对其及时进行修改，攻击者可以利用这些已知信息对设备进行破坏. Schneider Electric Easergy T300 是法国施耐德电气公司的一款用于电力行业的远程终端单元，使用 1.5.2 及之前版本固件的终端里存在逻辑漏洞(CNVD-2021-21479)[16]，该漏洞源于程序使用弱加密算法，攻击者可借助暴力破解的方式，利用该漏洞获取密码信息，进而控制终端、操作设备.

3.4 命令注入漏洞

命令注入漏洞指攻击者通过恶意构造的参数，将高危命令拼接到正常命令中，从而达到破坏系统或者获取敏感文件的目的.缺少对用户输入进行完备的检查通常是导致命令注入漏洞的主要原因，常见的命令注入有 SQL 注入、Shell 注入等.在物联网设备中，固件是直接与底层硬件进行交互的，拥有非常高的权限，所以命令注入会造成巨大的危害.对于包含操作系统的固件而言，它们支持运行命令行，虽然降低了固件的开发、部署成本，但这也给固件留下命令注入的安全隐患.尤其是固件程序缺少对外界输入命令行指令的校验逻辑时，物联网设备将暴露于执行高危命令的危险中.如攻击者可以构造特定的指令以获取设备上存储的文件或者查看数据库的内容，这会造成敏感信息泄露；可以执行如 rm -rf 这样的高危操作指令来删除系统上的重要信息，使物联网设备无法继续运行；可以通过 netstat 命令查看设备所连接的远程服务器的信息，并对其发起攻击. Discord Recon Server 是美国 Discord 公司的一个 AI 机器人.Discord Recon Server 存在代码注入漏洞(CNVD-2021-34351)[17]，该漏洞属于远程代码执行，利用该漏洞，远程攻击者可在服务器上执行命令.

3.5 固件修改漏洞

固件病毒存在于物联网设备的固件主板上，病毒会在每次设备启动时被加载，具有隐蔽性大、清除困难的特点.对于传统的病毒来说，操作系统级别的安全防御软件可以完成对病毒的查杀，最严重的情况下，通过重新安装操作系统即可完成清理.但是固件病毒驻留在设备主板上，传统防御软件无法读取此位置的内容，这是造成固件病毒检测困难、清除困难的重要原因.固件是运行在物联网设备上的核心软件，担任着一个系统最基础最底层工作，对下控制着底层硬件的操作，对上承载着设备的复杂功能，因此固件病毒对设备的危害极大.隐藏在固件中的病毒通过设备启动时被加载，攻击者通过留下的后门，可以获取敏感信息，如入侵智能摄像头查看视频监控.固件病毒还可以感染操作系统，实现病毒的复制与传播，大量被感染的设备形成巨大的僵尸网络，可以对目标网络发起 DDoS 攻击.此外，固件病毒必须通过专门的硬件检测工具才能发现，普通用户难以发现并清理病毒.因此可以得出固件病毒比普通病毒危害更大.Basnight 等人[18]阐述了将修改后的病毒固件

(C)1994-2022 China Academic Journal Electronic Publishing House. All rights reserved. http://www.cnki.net

上传到物联网设备的可编程控制逻辑器上.攻击者可以通过逆向工程,了解固件代码的更新逻辑,进而修改与更新相关的配置文件,以便在固件更新中注入恶意代码.

4 物联网固件漏洞分析面临的挑战

4.1 物联网固件难以获取

物联网固件难以获取主要体现在 2 方面:一方面,固件源码获取困难.大多数厂商为了保证设备安全与知识产权,不会公开固件源码的下载,或者一些厂商只提供了最新版本的固件,无法获得该固件的历史版本.另一方面,固件代码种类复杂.为了完成设备的各项功能,充分发挥各种程序语言的优势,固件代码里通常混有汇编以及 C,Java,Python,JavaScript,Php 等不同类型代码,这极大阻碍了后期反编译工作的进行.常用的获取固件手段包括从软件获取(如爬虫、模拟设备诱骗下载、App 内提取)以及从硬件提取.

4.1.1 通过爬虫获取

一些设备厂商公开了固件的下载地址,可以通过访问设备厂商的服务器获取公开可用的固件.对于未公布下载地址的设备,可以通过分析其固件时的网络流量,获得固件更新下载的地址.该方法不需要读取物理设备的硬件,Chen 等人[19]、Costin 等人[20]均利用该方法编写网络爬虫,从各大设备厂商的 web/ftp 服务器获取了几万个设备的固件.

4.1.2 模拟设备行为诱骗下载

这是一种从软件层面获取固件的方法,通过模拟物联网设备在真实环境下与云平台的交互行为,包括数据格式和传输协议等.如通过设备模拟向云平台直接发送固件更新的请求,或者间接将设备参数和设备过期的版本号等欺骗云发送固件下载链接,以达到获取最新固件的目的.在进行设备行为模拟时,通常将模拟设备发送请求的软件称为幻影设备,Zhou 等人[21]详细介绍了构造幻影设备的流程.

4.1.3 App 内提取

对于采用 BLE(bluetooth low energy),Thread,ZigBee 或者协议进行通信的设备,如手环、体重秤、智能插座,传输数据量小,具有小巧、低能耗的特点.这类物联网设备并不和云平台通过 WiFi 连接,当进行数据上报、固件更新时,以手机或者网关为中转,间接接入互联网.为了提升用户体验,设备厂商在手机应用程序中预先存储或者下载最新版本的固件,等手机和设备建立连接时再进行固件的更新升级.利用此特性可以分析手机内的文件,提取 App 里后缀名为.bin 或者.fw 的文件.

4.1.4 通过硬件提取

固件程序是保存在存储器中的,通过人工拆解物联网设备找到存储芯片,通过编程器读出芯片中的数据.除此之外,如果主板上的接口没被封死,还可以利用设备主板上的串口或联合测试工作组(joint test action group, JTAG)接口,将设备与电脑连接,使用配套的软件如 OpenOCD 等,可以硬件调试接口,读取设备中的内存信息,从而获取固件代码.硬件提取固件耗时,而且提取出固件后,可能致使物联网设备报废,浪费物力财力,导致实验无法继续进行.在实际研究工作中,通过硬件调试可以读取通信加密密钥,所以该方法常作为辅助手段,用于解密通信协议,辅助人工逆向工作.

4.2 固件格式差异较大

由于固件的格式复杂多样,没有统一的标准,一方面固件的代码风格、结构差异较大,另一方面固件运行于不同的硬件之上,其处理器架构和内存架构有较大差异,对于固件分析工具的可拓展性是巨大的挑战.当前对于固件的自动拆解工具主要应用于包含通用操作系统的固件的解析,因为这些设备固件的镜像通常是由简单的归档文档或标准的文件系统组成的,使用现有的工具如 binwalk 可以很容易解压.常见的使用通用操作系统的智能设备有智能路由器、智能摄像头.对于单片机固件和实时操作系统固件,现有工具往往需要首先获取固件二进制文件在存储器中装载函数地址,然后将二进制文件转换为可以分析的镜像文件.然而,这类固件在不同硬件上所使用的处理器、内存架构差异较大,其固件的文件格式不同,不同设备的装载规则不同.目前针对单片机固件和实时操作系统固件,对于高效识别装载基址、架构还没有一个很好的解决方法,已有的基址识别方案的准确率较低[22],因此,在解析固件的文件格式时,会产生误判或者无法处理成可分析的镜像文件.

4.3 符号信息缺失

符号信息缺失是物联网固件分析面对的另一

(C)1994-2022 China Academic Journal Electronic Publishing House. All rights reserved. http://www.cnki.net

个问题.在固件的开发过程中,C语言的IoT开源项目和标准函数库是开发者的首选.开发者一般采用静态链接的方式向设备写入固件,因为该方式将所有的二进制代码片段链接为一个二进制代码文件,有效地压缩了程序体积,设备运行代码的效率也得到提高.这对于存储、计算资源受限的物联网设备来说非常友好.但是从固件安全分析与逆向工程的角度来看,静态链接抹去了函数名、变量名等库函数的符号信息,导致无法区分设备厂商自定义的函数和标准库中的函数信息,增加了固件反编译的成本.而目前的静态分析工具例如Dtaint[23]依赖于分析数据源函数到漏洞触发点函数之间的数据流信息,由于静态链接方式导致符号信息的缺失,使用静态分析技术分析固件时将受到阻碍.

4.4 仿真困难

目前在动态分析领域,固件仿真对于漏洞挖掘技术十分重要.动态分析是通过仿真软件加载固件,使固件在虚拟环境中运行,并对固件进行模糊测试[24].常用的仿真软件有QEMU,它支持多种指令集,移植性好,仿真速度快,免费且开源,因此被广泛应用于固件安全性分析的仿真平台设计中.Chen等人[19]首次提出了基于QEMU对以Linux为基础的固件镜像进行大规模的动态仿真方法,并识别出体系结构的固件镜像的百分比高达96.6%,说明其仿真以Linux为操作系统固件能力是有效的.但由于固件格式的差异,在实际仿真其他类型非Linux操作系统的设备固件时,会造成QEMU模拟固件时大量出现崩溃的情况,主要是因为不同固件格式差异较大,仿真软件难以正确定位固件装载函数的地址或者无法访问厂商定制硬件的属性.此外,如何构造合适的测试用例也成为仿真困难的原因之一.由于固件的响应严重依赖外部信号的输入,而外设由于其类型丰富且内部状态复杂,因此为每个外设设计定制化的输入需要大量人力成本,此外也难以构造极端的输入场景,无法探索更深的路径.

4.5 运行环境受限

一方面,出于成本和安全考虑,开发人员会简化固件代码,裁去不必要的组件,保留核心代码,并在设备出厂时将其调试接口封死,很少有设备向第三方提供完备的调试接口,避免留有后门与外界直接交互,所以在固件运行时数据难以通过调试接口获取.另一方面,固件运行的硬件资源有限,如CPU算力不够、内存过小.即使可以通过静态插桩或二进制重写等技术,在物联网设备中部署动态分析方法也会因为受制于硬件资源,而影响到其分析结果.

5 物联网固件漏洞分析方法

分析物联网固件面临众多挑战,保障物联网设备安全的关键在于采用自动化的流程,高效检测固件漏洞[25].因此研究高效的自动化的固件安全漏洞检测方法具有重要意义.一方面可以在厂商正式发布固件之前检测出漏洞,有效避免未来受攻击所造成的损失;另一方面可以实现在有限时间内分析大量固件,节省人力、物力等成本.

目前主流的自动化漏洞检测技术可以分为4类,分别是静态分析技术、符号执行技术、模糊测试技术、机器学习技术.

5.1 静态分析

静态分析无需运行物联网设备,只对固件代码进行扫描,通过词法分析、语法分析、控制流、数据流分析等技术验证固件代码是否满足规范性、安全性、可靠性、可维护性等指标.通过分析程序特征发现漏洞,可以达到检测潜在安全漏洞的目的.由于设备固件程序涉及商业机密,厂商几乎不公开源代码或文档,获取固件代码极其困难,一般只能通过逆向工程,然后结合一些传统的程序静态分析技术进行漏洞挖掘.物联网设备固件的静态分析的一般步骤如下:

1) 提取出固件中需要分析的程序模块;

2) 使用逆向工具,将其转换为汇编语言或其他中间语言;

3) 结合二进制分析平台或者逆向工具,恢复程序变量、函数、结构以及CFG(control flow graph)等信息;

4) 结合静态程序分析技术,如模糊哈希[26]、污点分析[27]等,实施漏洞挖掘.

5.2 符号执行

符号执行[28]技术最早源于20世纪70年代中期,通过采用抽象的符号代替精确值作为程序输

(C)1994-2022 China Academic Journal Electronic Publishing House. All rights reserved. http://www.cnki.net

入变量，得出每个路径抽象的输出结果，收集执行路径约束集合，求解约束产生的测试输入，在给定的约束下，探索尽可能多的不同的程序路径，用于检查是否存在各种错误.但是大多数符号执行技术不适用于大型程序，存在路径爆炸的问题，随着程序规模的扩大，程序中有意义的路径呈指数级扩大.有些程序中存在无尽循环或递归调用，这更大大增加了有意义路径，增大了符号执行难度.

5.3 模糊测试

模糊测试技术最早出现于 1990 年，Miller 等人[29]使用模糊测试发现 Unix 系统中的漏洞.其核心思想是将自动或半自动生成的随机数据输入到一个程序中，并监控程序崩溃、错误和内存泄露等异常.针对固件运行时所处的环境不同，可以将模糊测试分为 2 类：基于真实设备环境的模糊测试；基于仿真环境的模糊测试.在固件分析中应用模糊测试技术，向运行固件发送大量有效或无效的输入，观察程序输出的行为特征.在常规自动化测试过程中，模糊测试扩大了代码覆盖范围，提高了代码覆盖率测试程度.但是模糊测试也存在一些问题，如具有较强的盲目性、测试用例冗余度大、对关联字段的针对性不强等.

5.4 机器学习

人工智能技术可以对设备收集信息，对信息进行深入学习和理解，在一定程度上可以弥补现有的检测和防御技术在自动化方面的不足[30].例如，使用一些机器学习、深度学习算法来挖掘已有的固件漏洞特征，并在代码中匹配已知漏洞，结合模糊测试自动进行恶意应用检测或漏洞挖掘，借鉴迁移学习思想融合不同平台的检测知识.随着物联网应用类型不断丰富，以及交互场景越来越复杂，利用人工智能技术提升威胁检测和防御方案的效果是值得继续深入研究的方向.

6 总结与展望

随着 5G、人工智能、区块链、IPv6 等技术的发展，物联网设备数量呈爆炸式增长，其安全问题也越来越得到学术界和工业的关注和重视.固件向下控制底层硬件，向上为复杂的设备功能提供支撑，

固件安全对物联网设备的重要程度是不言而喻的.但是在实际环境中，固件由于其格式复杂多样，并没有统一的标准，包括代码结构、处理器架构、内存架构的差异较大，阻碍了固件自动分析工具的可拓展性.虽然当前针对固件安全的重视程度得到加强，且研究也在不断地增多，但仍有不足和亟待解决的问题.

对于静态分析技术而言，针对特定格式的固件能起到有效的作用，但是其可扩展性差，测试某些类型的固件时会产生较高的误报，且当固件代码过多时，静态分析的难度会提高.目前随着边缘计算的兴起，更多的数据计算与处理的相关代码被加入到离数据更近的固件中，固件代码量的增加会阻碍静态分析.此外，设备厂商为了保护固件安全，混淆机制被应用于固件代码中，所以逆向工程的难度加剧.

符号执行是程序分析技术的主要研究方向之一，在软件测试等领域有很好的应用前景，学术研究已经相对成熟，很多企业以及科研机构都在积极尝试将符号执行技术用于产品中.在符号执行中，目前已经可以将固件的可执行 bin 文件输入参数，但是其扩展性差，针对不同类型的固件需要人工定制不同的符号执行，且存在路径爆炸的问题.

模糊测试可以分为在真实设备上运行和在虚拟机中模拟运行，前者面临真物理资源有限的问题，且关于固件运行时的信息几乎不能获取；后者所面对的挑战是目前的模拟器尚不能完全模拟硬件的所有真实状态，需要构造大量有效或无效的输入发送给模拟环境下的固件，构造的输入难以全面覆盖，因此对固件进行测试无法很好地进行.

此外，随着人工智能的发展，以此为依托的固件检测技术正成为安全领域的研究热点.因为该方法不受限于固件的架构，表现出良好的可拓展性，需要攻克的难点在于如何为固件特征提取，建立模型，选择合适机器学习算法.可以将目前在普通软件安全领域成熟的人工智能检测手段，快速地移植到固件的漏洞测试中，但是需要不断地调整参数改进模型来提高的训练效率和预测精度.

综上，只有及时解决固件安全分析中的诸多难点，提前发现物联网固件漏洞，才能有效地发现和防御攻击行为，让人们更安全地体验物联网时代的便捷.

(C)1994-2022 China Academic Journal Electronic Publishing House. All rights reserved. http://www.cnki.net

参 考 文 献

[1] Knud L. State of the IoT 2018: Number of IoT devices-market accelerating[EB/OL]. (2018-08-08) [2021-09-08]. https://iot-analytics. com/state-of-the-iot-update-q1-q2-2018-number-of-iot-devices-now-7b

[2] 李阳，郭晓萧，张延强. 智慧城市网络安全保障研究进展[J]. 信息安全研究，2021，7(11)：1084-1089

[3] Kumar D, Shen K, Case B, et al. All things considered: An analysis of IoT devices on home networks[C] //Proc of the 28th USENIX Conf on Security Symp. New York: ACM, 2019: 1169-1185

[4] Wind River Systems, Inc. VxWorks[EB/OL]. 2021 [2021-09-08]. https://www.windriver.com/products/vxworks

[5] Amazon Web Services. FreeRTOS[EB/OL]. 2021 [2021-09-08]. https://www.freertos.org

[6] Langner R. Stuxnet: Dissecting a cyberwarfare weapon[J]. IEEE Security & Privacy, 2011, 9(3): 49-51

[7] TeleSUR. Venezuela denounces US participation in electric sabotage[EB/OL]. (2019-03-08) [2021-09-08]. https://www. telesurenglish. net/news/Venezuela-Denounces-US-Participation-in-Electric-Sabotage-20190308-0021.html

[8] Joe T. Colonial hack: How did cyber-attackers shut off pipeline[EB/OL]. (2021-05-10) [2021-09-08]. https://www.bbc.com/news/technology-57063636

[9] Eric R. JBS cyberattack: From gas to meat, hackers are hitting the nation, and consumers, where it hurts[EB/OL]. (2021-06-02) [2021-09-08]. https://www.cnbc.com/2021/06/02/from-gas-to-burgers-hackers-hit-consumers-where-it-hurts.html

[10] Ponemon Institute. The Internet of things (IoT): A new era of Third-Party risk[EB/OL]. (2017-07-17) [2021-09-08]. https://www.ponemon.org/research/ponemon-library/security/the-internet-of-things-iot-a-new-era-of-third-party-risk.html

[11] JSOF Research Lab. Overview-Ripple20[EB/OL]. (2020-04-17) [2021-09-08]. https://www.jsof-tech.com/ripple20/

[12] 苏盛，汪干，刘亮，等. 电力物联网终端安全防护研究综述[J/OL]. 高电压技术：1-13 [2021-09-08]. https://doi.org/10.13336/j.1003-6520.hve.20210150

[13] CNCERT. Internet network security situation of China in 2020[EB/OL]. (2021-07-21) [2021-09-08]. https://www.cert.org.cn/publish/main/8/2021/202107211309445045257 72/202107211309445045257 72.html

[14] Xu Jun, Ning Peng, Kil C, et al. Automatic diagnosis and response to memory corruption vulnerabilities[C] //Proc of the 12th ACM Conf on Computer and Communications Security. New York: ACM, 2005: 223-234

[15] 国家计算机网络应急技术处理协调中心. CNVD-2021-62181[DB/OL]. (2021-08-16) [2021-09-08]. https://www.cnvd.org.cn/flaw/show/CNVD-2021-62181

[16] 国家计算机网络应急技术处理协调中心. CNVD-2021-21479[DB/OL]. (2021-03-23) [2021-09-08]. https://www.cnvd.org.cn/flaw/show/CNVD-2021-21479

[17] 国家计算机网络应急技术处理协调中心. CNVD-2021-34351[DB/OL]. (2021-05-13) [2021-09-08]. https://www.cnvd.org.cn/flaw/show/CNVD-2021-34351

[18] Basnight Z, Butts J, Lopez Jr J, et al. Firmware modification attacks on programmable logic controllers[J]. International Journal of Critical Infrastructure Protection, 2013, 6(2): 76-84

[19] Chen D D, Woo M, Brumley D, et al. Towards automated dynamic analysis for Linux-based embedded firmware[C]// Proc of the Network and Distributed System Security Symp. San Diego, CA: NDSS, 2016: 1-8

[20] Costin A, Zaddach J, Francillon A, et al. A large-scale analysis of the security of embedded firmwares[C] //Proc of the 23rd USENIX Conf on Security Symp. Berkeley, CA: USENIX Association, 2014: 95-110

[21] Zhou Wei, Jia Yan, Yao Yao, et al. Discovering and understanding the security hazards in the interactions between iot devices, mobile apps, and clouds on smart home platforms[C] //Proc of the 28th USENIX Conf on Security Symp. Berkeley, CA: USENIX Association, 2019: 1133-1150

[22] 朱瑞瑾，张宝峰，毛军捷，等. 一种基于匹配字符串地址判定ARM固件装载基址的方法[J]. 电子学报，2017，45(6)：1475-1482

[23] Cheng Kai, Li Qiang, Wang Lei, et al. DTaint: Detecting the taint-style vulnerability in embedded device firmware [C] //Proc of the 48th Annual IEEE/IFIP Int Conf on Dependable Systems and Networks (DSN). Piscataway, NJ: IEEE, 2018: 430-441

[24] Chen Jiongyi, Diao Wenrui, Zhao Qingchuan, et al. IoT fuzzer: Discovering memory corruptions in IoT through app-based fuzzing[C] //Proc of Network and Distributed System Security Symp. San Diego, CA: NDSS, 2018: 1-15

[25] 杨毅宇，周威，赵尚儒，等. 物联网安全研究综述：威胁、检测与防御[J]. 通信学报，2021，42(8)：188-205

[26] Li Yuping, Sundaramurthy S C, Bardas A G, et al. Experimental study of fuzzy hashing in malware clustering analysis[C] //Proc of the 8th Workshop on Cyber Security Experimentation and Test. Berkeley, CA: USENIX Association, 2015: 1-8

[27] Godefroid P. Random testing for security: Blackbox vs whitebox fuzzing[C] //Proc of the 2nd Int Workshop on Random Testing: Co-Located with the 22nd IEEE/ACM Int Conf on Automated Software Engineering (ASE 2007). New York: ACM, 2007: 1-1

[28] Baldoni R, Coppa E, D'elia D C, et al. A survey of symbolic execution techniques [J]. ACM Computing Surveys, 2018, 51(3): 1-39

(C)1994-2022 China Academic Journal Electronic Publishing House. All rights reserved. http://www.cnki.net

[29] Miller B P, Fredriksen L, So B. An empirical study of the reliability of Unix utilities[J]. Communications of the ACM, 1990, 33(12): 32-44

[30] 樊期光，彭华熹，齐文杰，等. IoT智能硬件安全威胁分析与应对方法[J]. 信息安全研究，2018，4(8)：722-727

李　涛

硕士.主要研究方向为交通建设的信息化和智能化.

552126247@qq.com

田迎军

主要研究方向为交通建设的信息化和智能化.

86841536@qq.com

葛阳晨

硕士.主要研究方向为深度学习、网络安全.

geyangchengyc@163.com

田　源

博士.主要研究方向为信息安全、大数据隐私保护、量子密码学.

redrainiety@bupt.edu.cn

李　剑

博士，教授，博士生导师.主要研究方向为信息安全、量子密码学.

lijian@bupt.edu.cn

(C)1994-2022 China Academic Journal Electronic Publishing House. All rights reserved. http://www.cnki.net